CYBERSECURITY PORTFOLIO | RISK ASSESSMENT & MITIGATION (NIST SP 800-30 REV. 1)

Vulnerability Assessment Report: Public Remote Database Server

Lead Auditor / Analyst: Syed Yasir Shah, Cybersecurity Analyst

Target Asset: Central Remote MySQL Database Server

Assessment Standard: NIST SP 800-30 Rev. 1 Risk Assessment Guide

Assessment Window: June 20XX – August 20XX

1. System Description & Background

The target asset evaluated in this assessment is an enterprise production database server supporting an international e-commerce organization. The server hardware consists of a high-performance multi-core CPU and 128 GB of RAM. The server runs on the latest enterprise Linux distribution and hosts a MySQL relational database management system (RDBMS). It operates via a dedicated static IPv4 address with persistent network connectivity, interfacing with backend application clusters, third-party marketing services, and distributed remote employees across international jurisdictions. Baseline data-in-transit security includes transport-layer encryption (SSL/TLS).

> **Vulnerability Alert:** Critical Exposure: The centralized MySQL database server has been exposed directly to the public internet without perimeter access restriction since company launch three years ago. Anyone with the public IPv4 address and listening port (default 3306) can attempt connections, creating an extreme attack surface for brute-force attacks, remote code execution exploits, and mass data exfiltration.

2. Scope & Assessment Purpose

2.1 Assessment Scope

The scope of this vulnerability assessment specifically focuses on the network accessibility, authentication architectures, and access control mechanisms governing the centralized database server. The evaluation covers a three-month operational window (June 20XX – August 20XX). Methodology and risk calculations are conducted in accordance with the National Institute of Standards and Technology (NIST) Special Publication SP 800-30 Rev. 1: Guide for Conducting Risk Assessments.

2.2 Business Purpose of the Asset

The database server functions as the central repository for mission-critical e-commerce operations. It stores and manages:

- • Customer Personally Identifiable Information (PII) including billing details, contact lists, and transaction histories.

- • Marketing campaign data, audience profiling metrics, and active conversion analytics.
- • Sales pipelines and proprietary business intelligence used daily by international remote marketing and sales teams.

Securing this system is essential to preserving ongoing business continuity, maintaining brand credibility, and complying with statutory privacy mandates.

3. Risk Assessment Matrix (NIST SP 800-30 Rev. 1)

Risk levels are calculated using standard risk assessment methodology: Risk = Likelihood × Severity. Both factors are evaluated on a 1–3 qualitative scale (1 = Low, 2 = Medium, 3 = High), yielding an aggregate risk score between 1 and 9.

Threat Source	Threat Event	Likelihood	Severity	Risk Score	Risk Justification
Hacker (External Threat Actor)	Obtain sensitive information via exfiltration / unauthorized access	3 (High)	3 (High)	**9 (Critical)**	Publicly exposed default port invites continuous brute-force, credential stuffing, and exploit scans from internet threat actors.
Employee (Internal Threat Source)	Disrupt mission-critical operations / accidental corruption	2 (Medium)	3 (High)	**6 (Medium)**	Broad access permissions and lack of least privilege increase the likelihood of accidental table drops or malicious insider manipulation.
Customer (External Client/User)	Alter or delete critical business information	1 (Low)	3 (High)	**3 (Low)**	While end customers do not have direct DB credentials, unauthenticated endpoints or SQL injection vulnerabilities could allow unauthorized modification.

4. Assessment Methodology & Approach

The risk scoring approach evaluated both technical architecture and daily business workflows. Likelihood scores were derived by analyzing the reality of maintaining open database ports on public IPv4 addresses with no network perimeter filtering. In cybersecurity threat modeling, an exposed listening port is continuously discovered by automated threat scanners (e.g., Shodan, Censys) within hours. Severity scores were evaluated based on the business impact of data loss, regulatory non-compliance penalties (such as GDPR and PCI DSS fines), and complete operational downtime resulting from database corruption or ransomware encryption.

5. Remediation Strategy & Technical Implementation

To eliminate the identified vulnerabilities while preserving the ability of distributed global employees to query data efficiently, the following layered defense-in-depth controls must be implemented immediately:

5.1 Network Perimeter & Access Control

- • IP Allow-Listing & Firewall Rules: Reconfigure the host firewall (UFW/iptables) and cloud security groups to reject all incoming public connections by default. Allow incoming traffic only from designated, trusted corporate IP ranges.
- • Virtual Private Network (VPN) Gateway: Deploy a secure corporate VPN (e.g., WireGuard or OpenVPN) with certificate-based authentication. Require remote workers across global locations to connect to the VPN prior to accessing database services.
- • Port Binding Hardening: Reconfigure MySQL configuration (my.cnf) to bind exclusively to localhost (127.0.0.1) or an internal private subnet interface rather than 0.0.0.0.

5.2 Identity, Authentication, and Access Management (IAM)

- • Role-Based Access Control (RBAC): Enforce the Principle of Least Privilege (PoLP). Remove generic root/admin access. Provision read-only analytical accounts for marketing personnel and restrict write/schema alteration permissions exclusively to database administrators.
- • Multi-Factor Authentication (MFA): Require MFA on all management gateways, remote jump boxes, and VPN connection endpoints.
- • Cryptographic Password Policies: Enforce strong complexity requirements (minimum 16 characters, mixed entropy) with automated credential rotation schedules.

5.3 Data Protection & Telemetry

- • Modern Protocol Upgrade: Deprecate legacy SSL and outdated TLS versions (TLS 1.0/1.1) in favor of TLS 1.3 for all data-in-transit, preventing man-in-the-middle downgrade attacks.
- • Audit Logging & SIEM Integration: Enable comprehensive MySQL audit logging to record query histories, failed authentication attempts, and data export events. Forward audit logs to a centralized SIEM for automated anomaly detection.